IT Security Risk Assessment Report

Executive Summary

Assessment: Proxmox Virtualized Environment — Metasploitable Vulnerability Assessment
Assessment Date: November 3, 2026
Assessment Tool: Greenbone Community Edition
Target System: Metasploitable VM 120 (`10.10.50.10`)
Assessment Type: Laboratory Vulnerability Assessment and Simulated IT Security Risk Assessment

Assessment Overview

A vulnerability assessment was conducted against an intentionally vulnerable Linux virtual machine hosted within a Proxmox virtualized laboratory environment. The objective was to identify security weaknesses, evaluate their potential business impact, and document recommended risk treatment actions using established IT risk management practices.

The assessment used Greenbone Community Edition to identify vulnerabilities affecting the target system. The findings were subsequently analyzed and documented in an IT Security Risk Register, with consideration given to the COSO Internal Control Framework and relevant security controls from NIST SP 800-53.

This project demonstrates how technical vulnerability assessment results can be translated into structured IT security risks, control considerations, and management recommendations.

Summary of Findings

The vulnerability scan identified the following findings by technical severity:

Greenbone Severity	Number of Findings
Critical	13
High	8
Medium	39
Low	6
Total	**66**

The 13 Critical scan results were reviewed individually. Two results associated with the same vsftpd backdoor vulnerability were consolidated, resulting in **12 distinct risks** documented in the IT Security Risk Register.

The assessment identified several significant security weaknesses, including:

- **Unauthorized remote command execution:** Exposed services and backdoor vulnerabilities could enable attackers to execute commands on the affected system. Greenbone demonstrated root-level command execution through the Ingreslock backdoor and command execution under a daemon account through DistCC.
- **Weak authentication and privileged access:** Passwordless rlogin access, an empty MySQL root password, default PostgreSQL credentials, and a weak VNC password increase the potential for unauthorized access.
- **Unsupported and vulnerable software:** The target system runs Ubuntu 8.04, an operating system that has reached end of life. Additional findings involve outdated or vulnerable application components.
- **Insecure service configurations:** Legacy remote administration services and an exposed Apache Tomcat AJP connector increase the system's attack surface. The assessment demonstrated unauthorized retrieval of an application configuration file through the AJP connector.

These weaknesses illustrate how insecure configurations, weak credentials, unsupported technology, and exposed services can collectively increase cybersecurity risk.

Business Risk Assessment

To demonstrate enterprise risk management practices, the technical findings were evaluated using a simulated production scenario in which the affected server supports business applications and is accessible from an internal corporate network.

A five-point likelihood and impact methodology was applied to the 12 registered risks.

The provisional inherent risk assessment produced the following results:

Inherent Risk Rating	Number of Risks
Critical	9
High	3
Medium	0
Low	0
Total	**12**

These ratings represent **illustrative business-risk assessments**, not the actual operational risk of the isolated laboratory system.

The analysis demonstrates that technical vulnerability severity and business risk are related but distinct. Business risk depends on factors such as system criticality, exposure, threat likelihood, business impact, and the effectiveness of existing controls.

Internal Control Considerations

The assessment considered the COSO Internal Control Framework, particularly the **Control Activities** component, to identify the types of safeguards relevant to the documented risks.

Proposed NIST SP 800-53 control mappings address areas including access control, authentication, secure configuration, system maintenance, and boundary protection.

The vulnerability findings indicate potential weaknesses that these controls are intended to address. However, the assessment did not include organizational policy reviews, control design testing, or operating effectiveness testing. Therefore, no conclusion is made regarding the effectiveness of an actual organization's internal control environment.

Recommended Risk Treatment

Based on the provisional risk ratings, nine risks were assigned Priority 1 (P1) and three were assigned Priority 2 (P2).

Recommended treatment activities include:

1. **Remove backdoors and restrict unauthorized remote execution.** Eliminate compromised or unnecessary services and investigate indicators of system compromise where applicable.
2. **Strengthen authentication and privileged access.** Replace empty, default, and weak passwords; disable insecure authentication mechanisms; and restrict privileged access.
3. **Upgrade or retire unsupported technology.** Replace the end-of-life operating system and remediate vulnerable application components.
4. **Reduce unnecessary network exposure.** Disable unused services and restrict access to administrative and application interfaces.
5. **Validate remediation effectiveness.** Conduct follow-up testing and vulnerability rescanning to confirm that corrective actions address the identified weaknesses.

Each risk has a documented treatment recommendation, simulated owner, priority, and proposed validation method in the accompanying Risk Treatment Plan.

No remediation activities were performed or validated during this assessment. Consequently, residual risk remains unassessed.

Assessment Limitations

This assessment was performed in a controlled laboratory environment against Metasploitable, a system intentionally designed to contain security vulnerabilities.

The findings should not be interpreted as evidence of vulnerabilities within an actual production organization.

Business impact assumptions, inherent risk ratings, risk owners, and remediation priorities were developed for educational and portfolio purposes. Management approvals, organizational control effectiveness, remediation completion, and residual risk were not assessed.

The detailed analysis focused on the 13 Critical Greenbone results. The additional High, Medium, and Low findings were included in the scan summary but were not individually assessed in the 12-entry risk register.

Conclusion

The assessment identified substantial technical weaknesses within the intentionally vulnerable target system and demonstrated a structured process for translating vulnerability scan results into documented IT security risks.

The resulting Risk Register, Risk Scoring Methodology, Risk Treatment Plan, and Executive Dashboard provide a foundation for risk-based remediation planning and management reporting.

The exercise illustrates the importance of combining technical security assessment with business impact analysis, internal control considerations, clear accountability, and remediation validation.

Overall Assessment Conclusion: Under the simulated production scenario, the identified vulnerabilities would warrant prioritized management attention and corrective action. The actual laboratory environment remains an intentionally vulnerable training system, and no production security assurance conclusions are implied.